

Control Room: key decisions

RACHIKET ARYA / COGNITION TAKE-HOME / 28 SEPTEMBER 2026

Question. Can Ops use Devin to produce internal tools while a shared runtime retains control over permissions, connections and releases? The experiment tests that boundary with refund review and vendor bank-change review. It does not implement thirteen apps or replace Power Apps' platform services.

Constrain what makers can change. Apps are declarative JSON definitions interpreted by trusted code. They select supported workflows and capabilities; they cannot introduce JavaScript, SQL, arbitrary URLs or new permissions. This sacrifices unrestricted customization to make a small set of controls enforceable. A new business primitive is an engineering change, not a maker override.

Guidance is not enforcement. Hooks and templates help developers notice mistakes earlier. Release validation and server-side authorization provide the actual checks. Definitions must be validated again when loaded by the runtime, so skipping the workshop does not bypass policy. In production, the app maker must not control the runtime, release checks or deployment credentials. This demonstration repository does not establish that organizational separation.

Share decisions, not just screens. The two workflows reuse authorization, self-approval prevention, reason capture, version checks, idempotency and transactional decision/audit writes. Refund rules additionally protect the remaining payment balance. Bank-change verification is synthetic fixture data, not evidence that anyone called a vendor. The tools record decisions; neither executes financial changes.

Separate creation from activation. A maker can propose a definition; a platform-admin demo identity activates a validated version locally. Catalog, workshop and review screens expose that path. Local activation is not cloud deployment. A content digest identifies a version; it is not a signature or protection against a trusted database administrator.

Review the shared layer. The first 71 tests passed, but independent probes still found audit data exposed without its declared capability and an interrupted release that damaged the prior active file. Devin repaired both; failure-injection checks verified the repairs. This is why the platform itself needs review. Passing tests supports the tested cases, not a general promise of safe generated apps.

Leave production dependencies visible. Identity selection is simulated, connectors use synthetic data, and audit storage is append-only through the API rather than tamper-proof. Real SSO, record/field entitlements, network isolation, protected CI, durable audit retention, backups and incident ownership remain production work. A shared runtime reduces duplication but also concentrates outage and upgrade risk.

Evaluate the ownership cost. Retain existing apps and pilot a low-risk new workflow. The important measure is total build, review and support effort for the second app. Migration requires identifiable license savings and a funded owner. Adding ten apps need not increase a per-user unlimited-app license bill. Keep the \$250K headline separate from spend that can actually be removed.

Keep provenance and time honest. Devin builds the software; Codex supplies research, orchestration, independent review and these materials. This version reuses the earlier 26-minute Devin prototype. Its time remains part of the same two-hour budget. Actual commands, outcomes and timing are recorded separately; a short build does not establish production readiness.